



ALERTA CRÍTICO DE SEGURANÇA

[CVE-2025-20352] Vulnerabilidade
Zero-Day em Subsistemas SNMP Cisco

[STATUS: EXPLORAÇÃO ATIVA]

[IMPACTO: DDoS / ROOT]

[PATCH: DISPONÍVEL]

Uma falha crítica de stack overflow no sistema operacional da Cisco permite que invasores controlem roteadores e switches corporativos ou os utilizem como armas de negação de serviço (DDoS).



A Ameaça

Classificada como Dia Zero (Zero-Day) de alta gravidade. Invasores manipulam pacotes SNMP via IPv4/IPv6.



O Risco (Pior Cenário)

Execução de código arbitrário. Acesso irrestrito (nível root) ao hardware de rede vital.



A Realidade

Já utilizada em campanhas maliciosas ativas após o comprometimento prévio de credenciais locais.

Matriz de Triagem de Ativos (Superfície Afetada)



Vulnerável (ALERTA CRÍTICO)

Sistemas Operacionais:



Cisco IOS, Cisco IOS XE

Hardware Específico:



Meraki MS390



Cisco Catalyst série 9300 (Meraki CS 17 ou anterior)



Seguro (NÃO IMPACTADO)

Sistemas Operacionais:



Cisco IOS XR

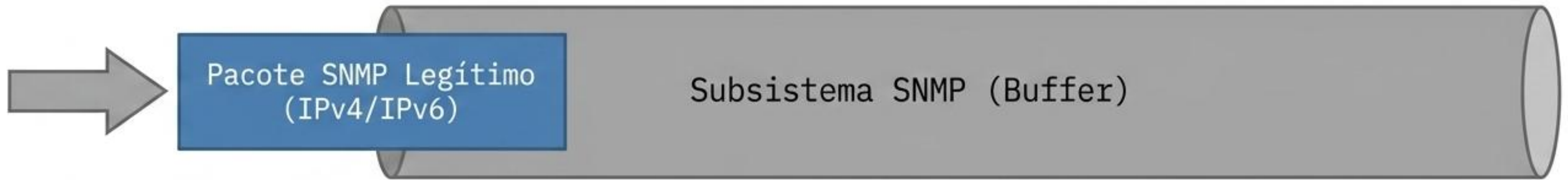


NX-OS

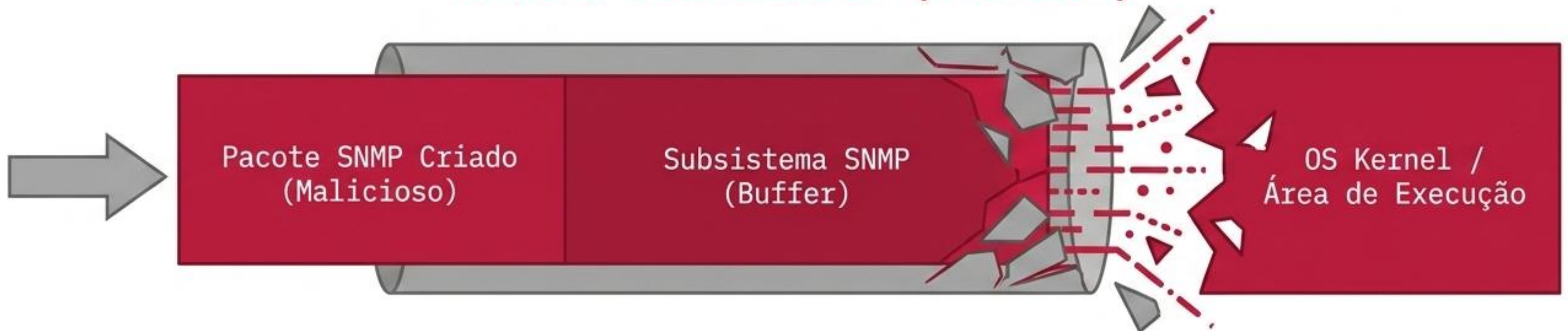
// REGRA GERAL: Todos os roteadores e switches rodando IOS e IOS XE estão comprometidos.

Anatomia da Falha: SNMP Stack Overflow

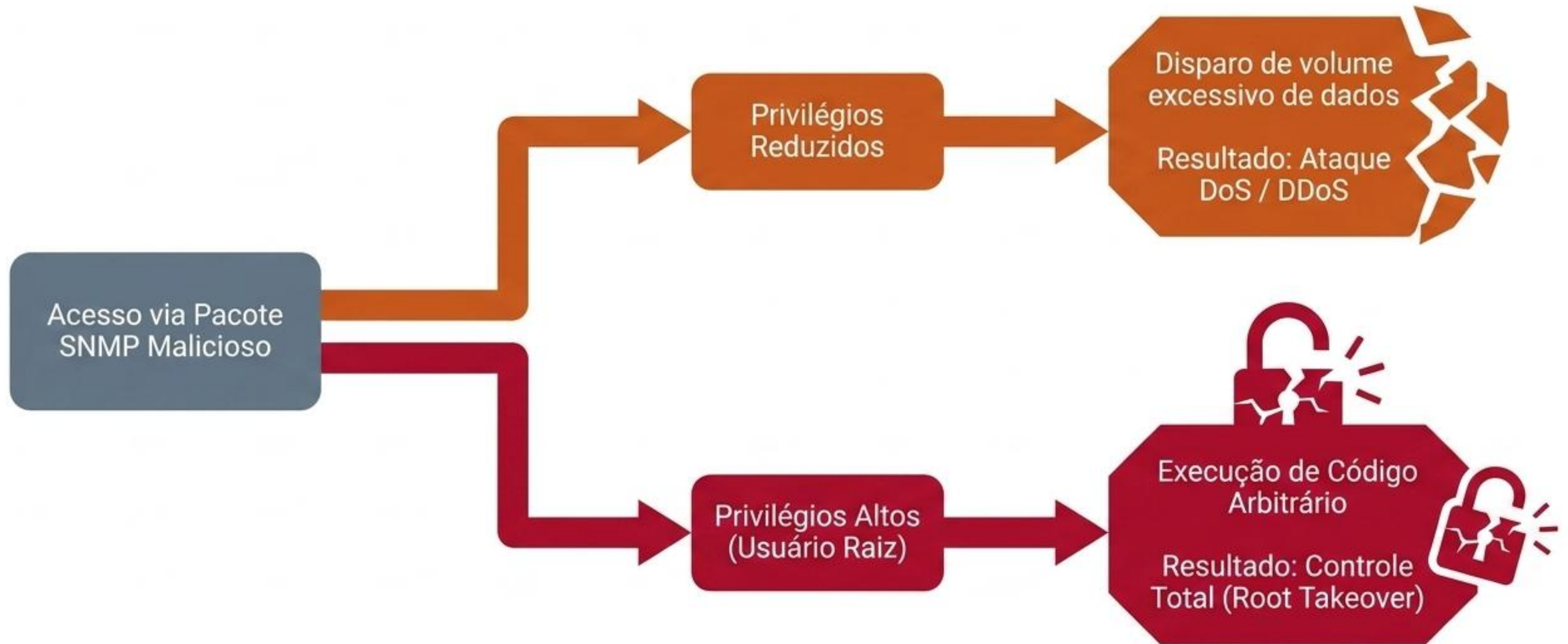
Operação Padrão



Memória Sobrescrita (Overflow)



Consequências do Impacto: Caminhos de Execução

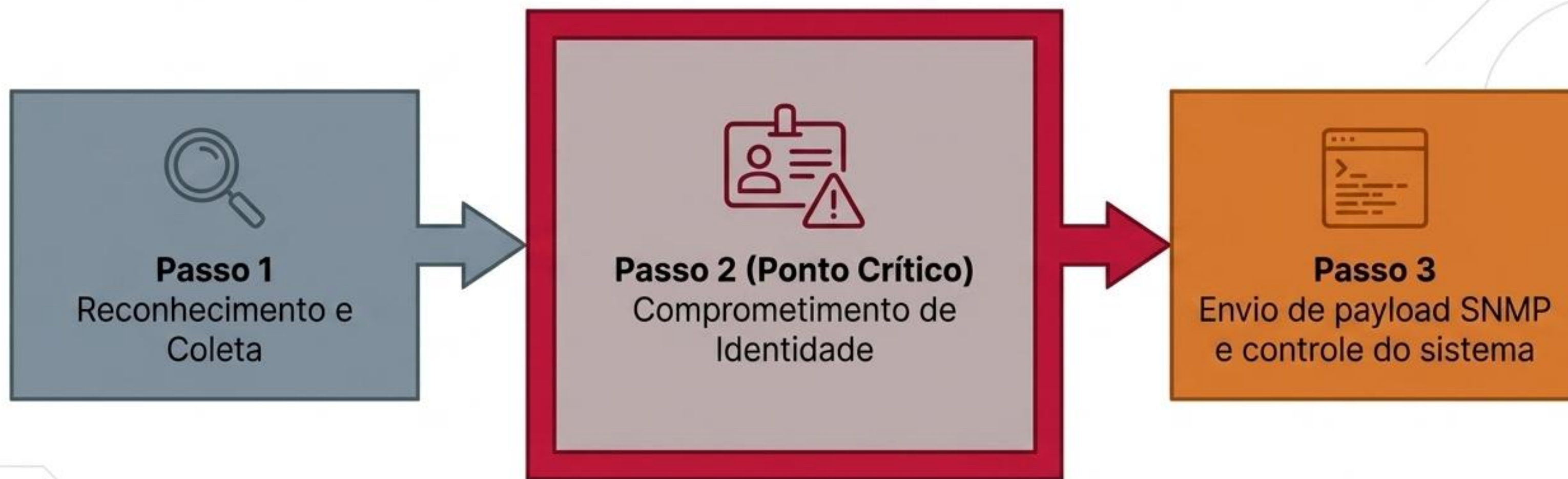


Vetores de Exploração: Requisitos de Credenciais

	Objetivo -> Ataque DoS	Objetivo -> Execução Root
SNMPv2c / v1	Requer: Community String "somente leitura" válida.	Requer: Community String "somente leitura" + Credenciais administrativas (Privilégio 15).
SNMPv3	Requer: Credenciais válidas de usuário SNMPv3.	Requer: Credenciais válidas de usuário SNMPv3 + Credenciais administrativas (Privilégio 15).

A execução de código (Root) nunca é cega. Ela exige, invariavelmente, o comprometimento prévio de credenciais administrativas nível 15.

Anatomia da Campanha Maliciosa Ativa



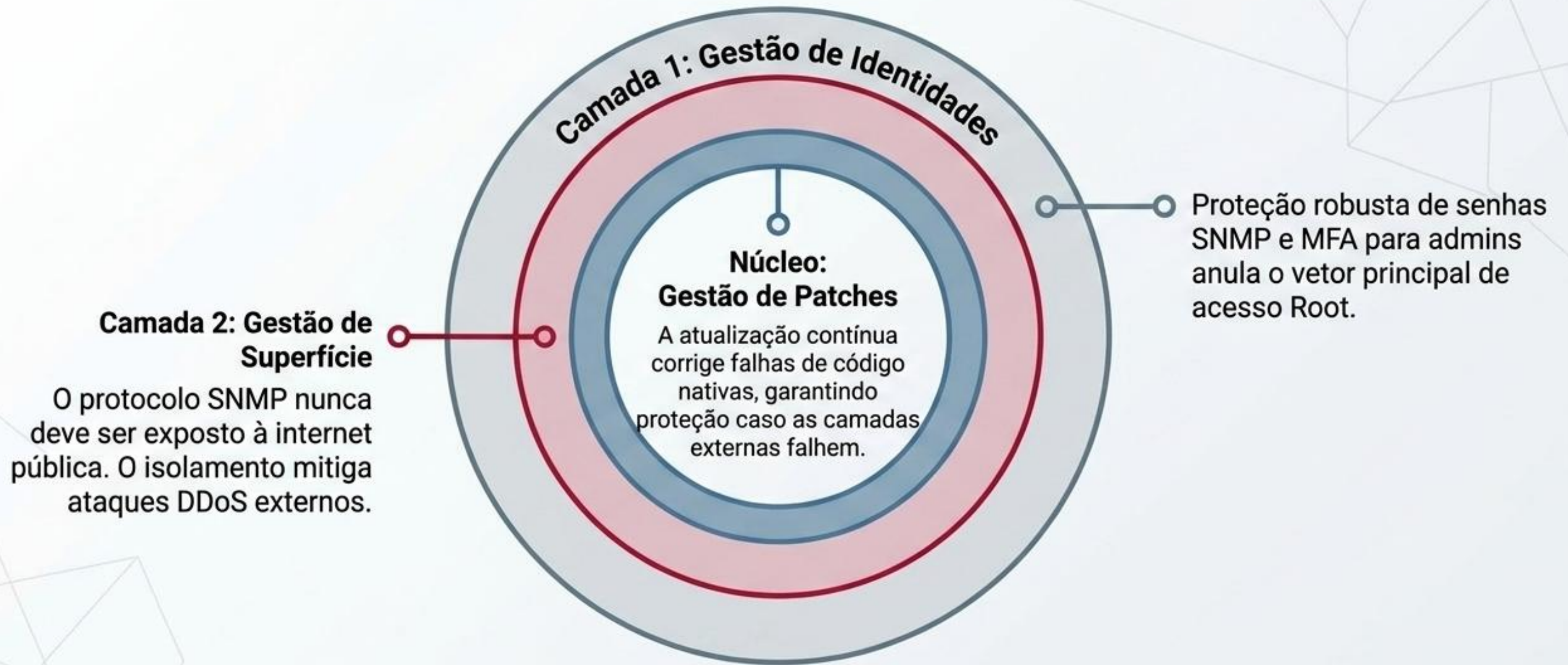
“

O Dia Zero dependeu de um erro humano inicial. A falha existe no código da Cisco, mas o gatilho foi o vazamento de credenciais de um administrador local.

Playbook Tático: Resposta e Mitigação Imediata



Postura Resiliente: Lições do CVE-2025-20352



Segregar acesso e rotacionar credenciais converte vulnerabilidades críticas em portas de entrada intransponíveis. Inicie a triagem agora.